



MONTRAN

National Bank of Georgia



Inception Report – Annex C – Security

Instant Payments System

Version: 1.00

Date: 2025-06-13

DOCUMENT CONTROL

Title:	Inception Report – Annex C – Security
Code:	GE_IPS_Inception_Report_Annex_C_Security
Project:	GE_IPS_2023
Confidentiality:	BUSINESS USE ONLY
Integrity:	HIGH
Availability:	MEDIUM
Deliverable:	Yes
Version:	1.00

DOCUMENT OWNERSHIP

NATURE OF INVOLVEMENT	NAME	INSTITUTION	ROLE
Owned by:	Sebastian Stefan	Montran	Technical Team Lead
First Draft by:	Romana Salageanu	Montran	Business Analyst
Last Verified by:	Sebastian Stefan	Montran	Technical Team Lead
Reviewed/QA by:	Sebastian Stefan	Montran	Technical Team Lead
Approved by:	NBG Payments, IT & Security teams	NBG	NBG Payments, IT & Security teams
Distributed to:	Nino Dziguashvili	NBG	Project Manager

DOCUMENT HISTORY

DATE	VERSION & STATUS	CHANGES
2024-02-12	0.01 DRAFT	First draft.
2024-07-24	0.02 DRAFT	Second draft.
2024-09-18	0.03 DRAFT	Answer to open comments
2024-10-31	0.04 DRAFT	Montran responses to NBG comments sent on 18.10.2024.
2024-11-19	0.05 DRAFT	Montran responses to NBG comments sent on 18.11.2024

DOCUMENT HISTORY

DATE	VERSION & STATUS	CHANGES
2025-01-22	0.06 DRAFT	Amendments based on onsite discussions and request for more details on 2FA. New section 3.3 System Implementation of 2FA added.
2025-04-03	0.07	Updates based on NBG comments from 18.02.025, calls and NBG communication from 02.04.25.
2025-06-13	1.00 APPROVED	Clean version based on NBG confirmation from April 15 th , 2025.

Use of this document, in conjunction with the PRODUCT is subject to the written agreement(s) between Montran and its customer. Use not contemplated by the written agreement(s) is expressly not permitted. This document may not be copied, redistributed, or used in any manner outside that which is permitted in the written agreement(s), except with written consent of Montran. Ownership in and copyright to this document remains with Montran at all times.

Table of Contents

1. Security	5
1.1. Overall Methods for System and Communication Security.....	5
1.2. Security within IPS.....	5
1.3. Security of Communication.....	6
2. Digital Certificates	7
2.1. Authentication of STP Systems to MPPM	7
2.2. Validation and Application of the Digital Signature.....	7
2.3. Certificate Issuance and Management	9
2.4. Key Usage Extensions and Extended Key Usage for Issued Certificates	9
2.5. Digital Certificates required for the IPS Central System	10
2.6. Digital Certificates required for STP Applications from Participants	11
2.7. CRL Files	13
3. Two Factor Authentication (2FA)	15
3.1. User Registration – Login without Default Passwords.....	16
3.1.1. Login Notifications	19
3.2. Passwords Security Policy	19
3.3. System Implementation of 2FA	20
4. Physical Site Security.....	22

1. Security

1.1. Overall Methods for System and Communication Security

IPS security standards are defined to achieve access security and interface security levels equivalent to the security levels of the SWIFT network or better. The design and implementation of the system security for IPS complies with the International Standard ISO/IEC 27002, and the requirements of the BIS Principles for Financial Market Infrastructures (PFMI) regarding:

- Management and security of access to the system
- Confidentiality of the exchanged information
- Authentication of the sender and received information
- Integrity of exchanged information
- Non-repudiation of received information by the sender
- Management, storage and use of cryptographic keys and digital certificates.

1.2. Security within IPS

IPS conforms to the highest level of international security standards by using PKI based security. The following security elements are provided within IPS itself:

- IPS access requires the User to authenticate her/himself with a User/password pair and the OTP code generated by the 2FA process, and to login from a list of allowed hosts (configured per user)
- IPS provides controls over access rights to specific functions based on User Profiles, enabling NBG to define the functionality to be assigned to individuals or groups within NBG.
- Participants will be connected to IPS via a WebStation for enquiry and interactive services using a secure SSL connection over TCP/IP.
- NBG will publish a certificate revocation list (CRL) as an accessible resource on both live and disaster recovery sites. This approach is preferred since using remote CRL's might impact the speed of the validation process and thus endanger the SLA.
- Transmission of all messages used to initiate interactive functions such as funding control will be secured by the SSL channel.
- All events are logged to a central logging system.
- Security breaches (or attempts thereof) are identified and logged in the system audit trails. If a blocked User tries to enter the system an alert is raised to the System Operator.
- IPS will provide NBG 's Security Officers with comprehensive audit trails for all business data in IPS module. Application logs will be sent to NBG centralized log system ArcSight ESM using the Syslog protocol.
- Protection of data against unauthorized modification will be achieved with Digital Signature.

- Messages entered manually at a WebStation are secured by the SSL channel.
- Messages entered from Core Banking/Financial Management Systems of Participants are secured by digital signature in the CBS.
- “Four-eyes check” principle is applied to all sensitive WebStation operations (transaction operations etc.).

1.3. Security of Communication

Within the system, communication channels are protected against interception and modification using SSL/TLS technology. Access to the application is only allowed after NBG authentication (applications and users). The communication channels subject to security requirements are:

STP – HA PROXY APPLICATION	TCP/443
Browser Internet – HA Proxy	TCP/443
HA Proxy – PM	TCP/443
HA Proxy - MMC	TCP/443
PM MMC – Cluster Kafka ⁴	TCP/9090-9091
MMC – PM	TCP/443
MMC ⁵	TCP/ 1575
MMC – Email Server	TCP/25 or 465
Kafka inter-site replication (Mirror Maker)	TCP/9090-9091

2. Digital Certificates

2.1. Authentication of STP Systems to MPPM

The client systems of the Participants are authenticated to the PM by certificates issued by an approved authority. Certificates are imported and managed in the MMC by the Participant or by NBG.

Because the IPS STP interface proposes a non-session protocol (no login, logout), authentication of the STP systems is performed for each operation initiated by them. The process is as follows:

- To establish an SSL connection, PM checks the existence of a certificate issued by an authorized authority (by configuring them in the SSLkeystore).
- Once the connection is established, it is verified that the certificate presented by the client application is part of the list of existing certificates in the system for the initiating party.
- If the certificate is present and meets all of the following conditions, access is permitted:
 - Active Status
 - Certificate imported into the system for communication authentication (TLS)
- Otherwise, the application access to the required function/operation is rejected at the communication protocol level, there is no message or response file.

To avoid unavailability issues when certificates expire, multiple certificates can be uploaded for the same Participant. Certificate management functionality is subject to RBAC mechanism, meaning that it can be limited to specific users only. This management does not require development, configuration or application restart. There is a configurable (number of days prior to) alert sent to participants and Operator users when a certificate is about to expire.

Authentication to the STP management interface only used by MMC is also accomplished through an SSL digital certificate. Thus, the SSL certificate issued for MMC is configured in PM to allow access to the STP management interface. This configuration involves importing the MMC certificate into SSLkeystore from MP and adding a parameter (alias from SSLkeystore) to a PM configuration file.

2.2. Validation and Application of the Digital Signature

All messages are signed by the Participant at the moment of transmission to the PM and the PM at the time of sending to the Participant. The format used is the one described in <https://www.w3.org/TR/xmlsig-core1/>, configured with the following parameters:

- Content canonization, <http://www.w3.org/TR/2001/REC-xml-c14n-20010315>.
- ENVELOPED transformation, <http://www.w3.org/2000/09/xmlsig#enveloped-signature>.

- Signature canonization, <http://www.w3.org/2006/12/xml-c14n11>.
- Digest, <http://www.w3.org/2001/04/xmldsig-more#ecdsa-sha256>.
- Signature, <http://www.w3.org/2001/04/xmldsig-more#ecdsa-sha256>.

The client library contains dedicated signing and verification methods.

The validation of the signature involves verifying the integrity of the XML document. It certifies that no changes have been made, followed by the validation of the certificate used, according to the following steps:

- The list of certificates associated with the sender's Participant is filtered out with the following features:
 - Active Status
 - Certificate imported into the system for verification of digital signature.
- Verify the validity of the digital signature of the XML message with the filtered list of certificates in the previous step. This verification consists of several steps according to the standards mentioned above. In short, it is determined whether the message was altered and whether the digital signature was produced using a private key whose public key is in the certificate imported into IPS.
- If the validation has a positive result, message processing continues, otherwise the message is marked as rejected with the corresponding error code, and the IPS sends the sender a response in pacs.002 format that indicates the rejection of the message.

Certificates are issued by an approved authority NBS CA. Certificates are imported and managed in the MMC by the Participant or by NBS.

The validation of the digital signature by the client library is similar to that performed by the central system with some differences:

- The issuer and serial number of the certificate contained in the XML message are used to identify the public certificate to the PM used for signing.
- Expiry validation is done of the PM certificate so identified and uploaded from DSkeystore.
- The certificate is used to validate the digital signature of the message. This checks the integrity of the message and the signature was generated with the private key of the PM.

The result of validation is reported to the Participant application by the client library, an application that is responsible for making a decision if this validation fails.

2.3. Certificate Issuance and Management

Certificate issuance and management will be implemented using Microsoft CA service (NBG CA).

2.4. Key Usage Extensions and Extended Key Usage for Issued Certificates

The following table describes the key usage extensions available for certificates created using the CA process.

TABLE 1 KEY USAGE EXTENSIONS

KEY USAGE EXTENSION	DESCRIPTION
Digital signature	Use when the public key is used with a digital signature mechanism to support security services other than non-repudiation, certificate signing, or CRL signing. A digital signature is often used for entity authentication and data origin authentication with integrity.
Non-repudiation	Use when the public key is used to verify digital signatures used to provide a non-repudiation service. Non-repudiation protects against the signing entity falsely denying some action (excluding certificate or CRL signing).
Key encipherment	Use when a certificate is used with a protocol that encrypts keys. An example is S/MIME enveloping, where a fast (symmetric) key is encrypted with the public key from the certificate. SSL protocol also performs key encipherment.

Extended key usage further refines key usage extensions. An extended key is either critical or non-critical. If the extension is critical, the certificate must be used only for the indicated purpose or purposes. If the certificate is used for another purpose, it is in violation of the CA's policy.

If the extension is non-critical, it indicates the intended purpose or purposes of the key and may be used in finding the correct key/certificate of an entity that has multiple keys/certificates. The extension is then only an informational field and does not imply that the CA restricts use of the key to the purpose indicated. Nevertheless, applications that use certificates may require that a particular purpose be indicated in order for the certificate to be acceptable.

If a certificate contains both a critical key usage field and a critical extended key usage field, both fields must be processed independently, and the certificate be used only for a purpose consistent with both fields. If there is no purpose consistent with both fields, the certificate must not be used for any purpose.

TABLE 2 MAPPING BETWEEN EXTENDED KEY AND KEY USAGE

EXTENDED KEY	ENABLE FOR THESE KEY USAGE EXTENSIONS
TLS Web server authentication	Digital signature, key encipherment or key agreement.

TLS Web client authentication	Digital signature and/or key agreement.
Email protection	Digital signature, non-repudiation, and/or key encipherment or key agreement.

2.5. Digital Certificates required for the IPS Central System

The IPS solution will allow NBG's operators and Participants' users to import the digital certificates used by the Participants into the system database. The import of certificates is performed in MMC using the graphical interface. If the function is used by the user of a Participant, then the system allows only the import of the certificates of that Participant. NBG's operators can upload certificates for any Participant defined in the system.

In addition to the default List, Create, Modify, Remove, and Approve operations applicable to all entities managed by the system, Digital Certificates also support the following operations:

- Block
- Unblock

To secure applications, issue the following types of certificates:

- **SSL server issued in private hierarchy** (i.e., issued by a CA whose root certificates are pre-installed in client browsers): minimum 1 SSL server certificate per environment (test, production - this certificate can be shared by all applications processing).

To avoid the simultaneous expiration of the certificate on the two sites, it is recommended to issue an SSL server certificate on each site.

- **Digital signature certificates issued in a private hierarchy.** These certificates are installed on the processing nodes for signing payment messages – recommended 1 certificate per site. For this certificate, it is recommended to use a private/public key pair using Elliptic Curve (ECDSA) algorithms. The certificates used for the digital signature must contain the "non-repudiation" attribute. These certificates are saved in JKS (DSkeystore) keystores for each PM instance.
- **SSL server certificates (private hierarchy).** These certificates are used to secure connections between processing nodes: one certificate per node. Components that require SSL certificates for communication security are PM, MMC, Kafka.

The required certificates for a site are presented as an example in the table below. For each certificate the required extended key usage is noted, for the key usage extensions see table: Table 2 Mapping between extended key and key usage.

TABLE 3 REQUIRED CERTIFICATES

MODULE	CERTIFICATE TYPE	QUANTITY
PM	SSL issued by a private authority (NBG CA); the certificate of this private authority must be imported into a truststore (keystore) that will deliver the STP applications to the Participants. Extended key usage: TLS Web server authentication.	1 copied on all 3 nodes on a site.
PM	DS issued by a private authority (NBG CA); the certificate of this private authority and the public key of the DS certificate must be imported into a truststore (keystore) that will deliver the STP applications to the Participants. Extended key usage: Email protection.	1 copied on all 3 nodes on a site.
MMC	SSL issued by a recognized authority to be automatically recognized by browsers. Extended key usage: TLS Web server authentication + TLS Web client authentication.	1.
Kafka	SSL issued by a private authority (NBG's internal). Extended key usage: TLS Web server authentication.	3, one certificate for each node.
Email Server	SSL issued by a private authority (NBG's internal)	1, if the Email server installation does not already have a certificate.

The Message Switch module is a distinct module, but it is a client module, so it does not require its own certificate. The Message Switch has a keystore to import the SIB public certificate to make the SSL connection with the SIB (server component).

Updating the keystore files containing the certificates requires rebooting the affected modules. For this reason, we recommended the use of private hierarchy certificates with a 5-to-10-year length of validity for internal SSL communications (Kafka).

Certificate aliases in keystore files are configurable parameters for the PM and STP client library, the default values being "server" for an SSL certificate of a server component and "signer" for a certificate used for the digital signature.

2.6. Digital Certificates required for STP Applications from Participants

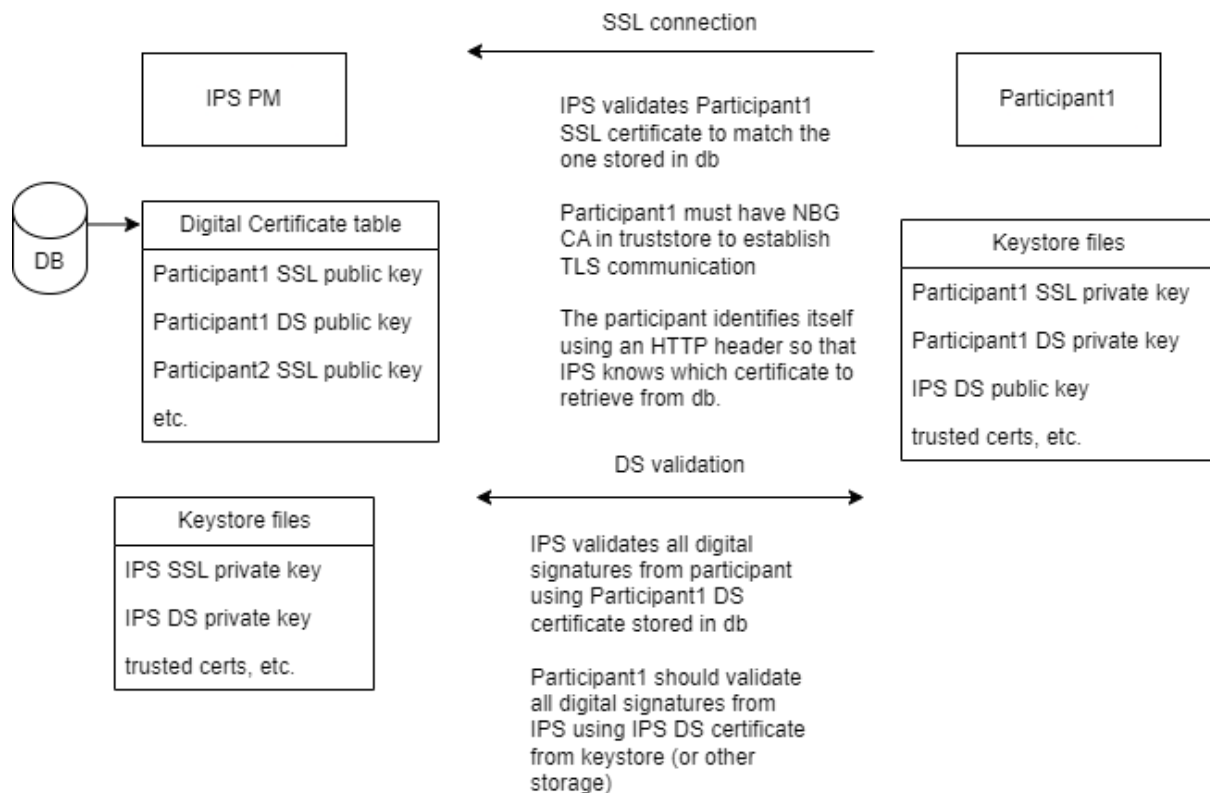
SSL client certificates issued by NBG CA. This certificate must be imported into IPS using the MMC GUI, as SSL. These certificates are saved to SSLkeystore (JKS format) files for STP applications to authenticate and secure the HTTP connection. In the context of the STP Authentication SSL connection, the SSLkeystore file must contain at least:

- Your own SSL certificate issued for the Participant's STP application. This certificate must be imported into IPS to allow the application to connect to PM.
- The private key associated with the above public certificate. It should be the only place where this private key exists. Used to establish the SSL connection.
- The issuer's public certificate (CA) that has signed the above Participant's SSL certificate or the trust chain if there are intermediary issuers.
- The issuer's public certificate (CA) that issued the public certificate installed in the PM or the trust chain if there are intermediary issuers. This is required to ensure trust in the SSL certificate of the PM that is received by the STP application when initiating the SSL connection - authenticating the server.
- **Extended key usage:** TLS Web client authentication.

Digital signature certificates issued by NBG CA. This certificate must be imported into IPS using the MMC GUI, as DS. For this certificate, it is recommended to use a private / public key pair using Elliptic Curve (ECDSA) algorithms. The certificates used for the digital signature must contain the "non-repudiation" attribute. These certificates are saved in JKS keystore (DSkeystore). In the context of the STP Application for Digital Signature Application and Validation, the DSkeystore file must contain at least:

- Your own DS certificate issued to the Participant's STP application. This certificate must be imported into the IPS to allow validation of messages signed by the Participant. The DSkeystore file can contain several valid DS certificates, but only one is used by an application, identifying by configuring the library with the alias of the certificate used.
- The private key associated with the above public certificate. It should be the only place where this private key exists. It is used to apply the digital signature.
- The issuer's public certificate (CA) that has signed the above Participant's DS certificate or the trust chain if there are intermediary issuers.
- The Public DS certificate and the issuer's public certificate (CA) or the trust chain if there are intermediary issuers. This is required for the STP library to validate the digital signature applied by the PM. This certificate must be present in the DSkeystore file to the Participant because it is not included in the XML message that is received from the central system. The digital signature in the XML message contains only the signature itself and identification information of the certificate used for signing (issuer's name and serial number of the certificate).
- **Extended key usage:** Email protection.

IPS API security using digital certificates is outlined in the diagram below:



2.7. CRL Files

To verify the revocation of Participants' digital certificates (user certificates and STP applications), IPS uses CRLs published by CAs issuing certificates. CRLs obtained from the CA will be distributed by OS copy on all processing nodes (PMs), and MMCs. Both IPS modules monitor a specific directory ("cr1-dir") to detect the presence of new or updated CRLs. The directory can be a local or local mapping of a remote directory. The cr1 import directory must be readable for the application, and the copy process must be secure in terms of partial file readouts (e.g., file copying with .tmp extension, followed by renaming with .cr1 extension). Application modules will only read files with the CRL extension and will consider file system information available (last modification time) to detect updating a file.

For the Processing Module the CRL is checked on every digital certificate validation (for every participant SSL connection or DS applied on messages). When the application checks the CRL it will first compare the last modified timestamp for files on disk and if it's newer than in memory cache it will re-load them and then validate the certificate.

The Management Module will monitor CRL files periodically within 5 minutes, and if an updated CRL file is detected, it is loaded into memory and processed. This processing consists of passing certificates that comply with the following conditions in the Revoked status:

- the certificate appears in the processed CRL file

- The certificate is present in the system in the ACTIVE or BLOCKED state (If it is in the EXPIRED or DELETED state, the certificate is not modified)

The validity of CRL files depends on the periodicity of their publication by the CA, taking into account non-working days, if there is an impact. If the CRL file is expired, certificate revocation validation fails, and processing requests are rejected.

If the update of CRL files cannot be performed successfully, certificate revocation validation can be disabled by a system parameter without requiring the application to be restarted.

Validation of the revocation of Participants' STP (SSL and DS) certificates imported into the system is made by the Management Module strictly on the basis of the certificate status, which may be ACTIVE, REVOKED or EXPIRED.

3. Two Factor Authentication (2FA)

Two-factor authentication (also known as 2FA or dual authentication) increases account security by using two methods to verify your identity and adds a second layer of security on top of a password. 2FA involves authenticating yourself in two different ways. It works by using two unrelated authentication methods to secure an account. The second authentication method usually needs to be verified with something in your personal possession — such as your phone — in addition to your normal username and password.

2FA is based on a combo of factors:

- **Knowledge factor – the password.** This is something you know; it can't be physically lost but it can be copied.
- **Possession factor – the phone.** This is something you have; it can be physically lost but can't be easily copied.

Now, think of your office door code (knowledge factor) and your office key (possession factor). If you want to enter the office, you need both. This is an example of two-factor authentication, because it relies on something you know (code) and something you have (key).

A one-time password (OTP) is an automatically generated numeric string of characters that authenticates a user for the login session. OTP covers the possession factor of the 2FA. The OTP is generated by something that is your possession – i.e., the phone.

Each OTP is intended for use by only one user, is valid for a specific period of time, and becomes invalid after the user successfully logs in.

The time-based one-time password (TOTP) algorithm assumes that the system times are synchronized. This means that the TOTP validation server and software-token app use their respective system times. To minimize time drift, you should configure the network time protocol (NTP). Time differences between the TOTP validation server and a mobile device can result in a mismatch of the OTP, and subsequent login failure.

OTP registration requires the pairing between the central system and the user's phone:

- The installation of an OTP mobile app on the phone (for example Google Authenticator).
- Registration of the device for OTP purposes:
 - Central system creates a secret key for the user. The secret key is displayed in dual mode: QR and text.
 - On the mobile app, the secret key is processed. The user scans the QR displayed or manually enters the text of the secret key.
- The Google Authenticator app generates a 6-digit code, and the user enters the code on the registration page to finish the pairing between the central system and user's phone.

The central system creates a mapping between the username and the secret key. Usernames are unique and also are the secret keys attached to the username. Each time the user is no longer in possession of the phone (phone is lost / new personal phone is used), the secret key needs to be regenerated. The whole pairing processing between the Central System and the phone needs to be replayed. The user must ask the System Operator for the OTP token reset.

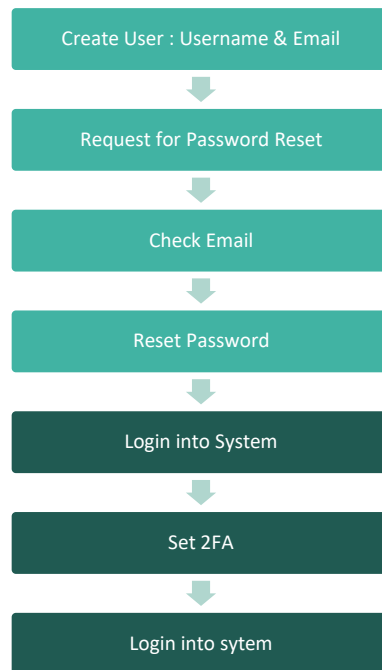
The OTP registration is done during the first login attempt. After that, the central system login procedure asks for the OTP usage all the time, for all the users.

The user is responsible for limiting access to its own device so that a malicious agent will not be able to copy their secret key. Therefore, it is recommended to set a pin or biometric lock mechanism for the phone and to use a personal account (to restrict the ability of accidental sync to another device).

3.1. User Registration – Login without Default Passwords

This User registration strategy enables the User to start the system login process without the default password set by the System Operator. The necessary Login data will be provided via its personal email. During the User's System registration process, the User will receive via email the Reset Password Token needed for password setup. An Email server will serve the purpose of sending emails to the User's personal email address. This is the recommended strategy for system User registration.

OTP functionality requires the user to have a personal smart phone and the installation of Google Authenticator app. The mobile app is free and it is available on all mobile platforms (Android and IOS). The OTP is a six-digit code generated by a mobile app that is used for only one login session. Every 30 seconds the app generates a new OTP. On every system login, the user must enter the password followed by the OTP code (in the same input field).



1. Create User

The User requests the System Operator access to the central system. The User provides the following mandatory information during the registration process:

- Full Name
- Email Address
- Mobile Phone Number
- Group Name: Participant Group / Admin Group.

The System Operator creates the user in the central system. IPS communicates the username back to the User using SMS. . Email, Mobile Phone Number and Username are validated for duplication by MMC. If the application receives a delivery report from the SMS gateway it will also be displayed in the MMC.

2. Request for Password Reset

The User gets hold of the system username created by the System Operator and accesses the central system Login page (the URL of IPS system will be communicated through an auxiliary channel, i.e. part of the user manual and during training or an Operator portal for participants if there is one). From the Login page, the User requests the password reset. In order to reset the password, the username information must be completed.

3. Check email

The central system processes the request to reset the password for the username and sends via email the Password Reset Token. The Password Reset Token is a text of 43 characters long, randomly generated by the central system. Its lifetime is equal to the user session timeout configured by the application server.

The User must wait for the email in order to continue the login process. The waiting time is up to a couple of minutes. The User must not leave the browser page otherwise the whole process must be replayed.

4. Reset password

The User receives an email with the Password Reset Token information. The token can be copied from the email and pasted into the MMC input field. The User must set its password according to the password policy rules enabled by the central system. The User enters the following mandatory information:

- Password Reset Token (received via email)
- New Password
- Password Confirmation

The central system validates all data entered. Next, it prepares for the Two Factor Authentication and the OTP integration. The User must Login the system.

5. Login into System

The User must Login into central system and provide the following mandatory information:

- Username (received from the System Operator)
- Password (freshly created password)

The central system notices that the User has no OTP setup done and forces the User to register for Two Factor Authentication (2FA).

6. Set 2FA

The central system creates a unique Secret Key for the User. The Secret Key needs to be added inside the Google Authenticator mobile app. Once the Secret Key QR is scanned, the mobile app will generate OTP codes every 30 seconds. Inside the mobile application, there can be multiple accounts each having different Secret Keys. By default, the account name will have system name and username, example: Central System (user1).

The User must do the following:

- Open the Google Authenticator
- Scan the Secret Key QR/ manually enter the Secret Key
- Enter the SIX-digit Code (OTP) generated by the mobile app

The central system validates all data entered. Also, it creates a match between the username and the validated Secret Key. All subsequent system logins will follow 2FA principles.

Warning: The Secret Key is valid until the OTP validation code is submitted to the central system. Failure to submit the valid OTP code will require the whole 2FA process to restart. Each time, the central system will generate a new Secret Key. Inside the mobile app, the User needs to remove the previously reregistered Secret Keys. The central system will provide error messages in cases when the OTP codes are invalid.

7. Login into System

The User must Login into central system and provide the following mandatory information:

- Username (received from the System Operator)
- Password (created by the user) + OTP code (generated by the mobile app)

The central system notices that the User has OTP setup done and will validate the password and the OTP code. Failure to provide the correct username/password and OTP code will result to unsuccessful login. After exceeding the maximum invalid attempts configured by the central system, the user account will be disabled and the User will need to ask the System Operator to activate the user account.

3.1.1. Login Notifications

IPS sends login notifications for each user in the following scenarios:

- “Your first attempt to log in failed” – this notification will be used for the first unsuccessful attempt of the authentication into the IPS
- “You are blocked due to multiple unsuccessful attempts to log in” – this notification will be used after multiple consecutive unsuccessful attempts (configurable in the user menu) of authentication into the IPS
- “You were successfully logged in to IPS” – this notification will be used for the successful authentication into the IPS

The System Operator can configure, per user, through which channel (SMS or Email), IPS sends the login notifications listed above. These notifications are sent by IPS to the affected users only and are separate from the alerting mechanism. Additionally, there is an alert that is also generated when a user is blocked “User was blocked” (described in the Inception Report – Alerting section) which is also generated when a user is blocked due to multiple failed logins (same condition as notification) and is sent to the System Operator.

3.2. Passwords Security Policy

The system allows a user to change his password in accordance with the security policy rules. Also, IPS is forcing password change at the first login after user creation, and at password expiration. IPS allows a user to change the password. The number of days before password expiration is displayed in the user interface for each user.

The IPS allows configuration of password security policing. This policy is complied with by all password-related operations as long as these operations are executed through IPS. Thus, IPS provides NBG with a set of parameters to govern the users' password definition, modification and expiration operations.

	PARAMETER NAME	DESCRIPTION
1	Minimum password length	A valid password cannot be shorter than the value of this parameter.

2	Minimum usage period (days)	This parameter specifies the minimum number of days after which your password can be changed.
3	Validity of the password (days)	A password has a limited validity in days that cannot exceed this value. The user is notified after Login with a configurable number of days before the expiration of the password.
4	Standard password validity (days)	When creating a user, the administrator can define the password's validity that cannot exceed the value of the Password Validity parameter, and the default value for this option is given by this parameter.
5	Password expiration notification period (days)	The expiration of the password is notified to the user, with a number of days in advance. This parameter specifies the number of days.
6	Number of previous passwords	When changing the password, the user is forbidden to reuse one of the last passwords he has used. This parameter specifies the number of passwords in the past that the user cannot reuse.
7	Maximum retry count	The user can retry a password for a maximum of times. This parameter specifies the maximum value that can be configured for a user
8	Number of retries	The default value that is given to the administrator when creating a user to determine the maximum number of re-attempts allowed to the user at authentication. The value cannot exceed the Maximum retry count in the system.
9	Minimum number of accepted complexity measures	There are 4 complexity criteria for defining a password that are explained in the following parameters. The IPS requires a minimum number of measures to be used for any of the 4.
10	Minimum number of digits	The minimum number of mandatory digits in the password.
11	Minimum number of symbols	The minimum number of mandatory symbol characters in the password.
12	Minimum number of uppercase characters	The minimum number of capital letters mandatory in the password.
13	Minimum number of lowercase characters	The minimum number of lowercase mandatory in the password.

3.3. System Implementation of 2FA

IPS implements the Time-Based One-Time Password Algorithm (TOTP) as described in RFC6238 standard. The implementation is part of the solution, and it is fully contained in the MMC component. Therefore, the 2FA authentication mechanism has the same high availability guarantees as the MMC.

If the MMC is not working, then authentication will not work either but there would not be a system to login into anyway (since MMC contains the user interface functionality). 2FA is completely separated from transaction processing which is localized on the PM component and is secured using digital certificates.

TOTP ALGORITHM PARAMETERS

The size of the time window used for OTP generation is configurable, as a Java System Property: TOTP.timeWindow (defaults to 30 seconds as per RFC6238 recommendations). In the default scenario, a new OTP is generated every 30 seconds.

The time steps used for validation are also configurable as a Java System Property: TOTP.stepWindow (defaults to 1 as per RFC6238 recommendations). This means that even if the code was sent by the client at the beginning or end of the time window the server will still consider it valid because it will also check the previous and next windows (with a step size of 1), essentially increasing the maximum interval allowed for desynchronizations between the applications. Typically, mobile phones automatically synchronize to a time server whenever they are connected to a network, therefore the desynchronization risk is low from the client side.

AUTHENTICATION FALLBACK

There are two configurations for TOTP user mapping:

- Enabled for all users: the recommended and default setting for the production environment
- Enabled on some users, can be set manually by the users themselves. This setting is enabled for the testing environment, to simplify access to the system where security is not a big concern.

In order to change the authentication method (either between the options for TOTP described above or to a certificate based one instead of TOTP) the system must be restarted, and some configuration parameters must be manually set by the Operator. In case of switching to a token-based model then those tokens must have been prepared and distributed to users previous to the contingency scenario, to ensure a smooth transition.

TOTP Algorithm works based on timestamps, therefore there is no need for the client devices (mobile phones) to be online all the time. Authentication can be performed even if the device is not connected to the internet, mitigating the risks associated with network issues. TOTP has shown to be a reliable mechanism for authentication and the only concern which may impact validation (desynchronization between server and client times) can be handled by increasing the OTP validation interval (described in TOTP Algorithm parameters section).

4. Physical Site Security

NBG as the system owner is responsible for physical site security at both its Live and Disaster Recovery sites at which the system is installed. As IPS is a mission critical system it is essential that the level of access security, backup power, air conditioning and fire prevention and suppression are satisfactory and in accordance with best practices.

Access to the computer room by cleaners, suppliers' engineers or premises staff etc. should be supervised at all times by an authorized NBG representative (on the main site) or NBG's computer operators or the management of the IT Division (at the DR site in NBG Head Office).

The same policy applies to the sites of Participants (Participant's responsibility) or at any Access Point site (if NBG should decide to open others except the one established in NBG's Head Office) used to access the IPS system.

PROJECT: <i>GE_IPS_DELIVERY_PROJECT</i>			
Date	2025-06-13	Deliverable Management Module	
Deliverable ID	01		
Deliverable Name	Annex C - Security		
Deliverable Code	GE_IPS_Inception_Report_Annex_C_Security_v.1.00		
Deliverable Type	DOCUMENT		
Version	1.00		
Description	Security		
Montran QA	QA Team		
Deliverable Review and Approval			
Delivered by:	Nucu Dumitrascu Project Manager Montran	Signature:	
Approved by:	Beka Dotchviri Executive Director National Bank of Georgia	Signature:	
Expected review date:	2025-06-13	Actual review date:	